

CS & AI • EXPLAINED

How are **passwords** kept safe?

A good website never even knows your real password.

THE HOOK

Here's something wild: a well-built website **never knows** your actual password.

Not the staff, not their database — **nobody**. Even they can't see it.

So how do they check you got it right? 



TODAY'S QUESTION

If a site never stores your password,
how does it **check** you typed it right?

It saves a **fingerprint**, not the password.

- When you sign up, the site does **not** save your password.
- Instead it saves a **hash** — a scrambled “fingerprint” of it.
- The real password is never written down anywhere.

THINK OF IT LIKE

A lock made from your password — but you can't get the password back from the lock.

Easy forward. Impossible backward.

• • •

```
# a hash function
```

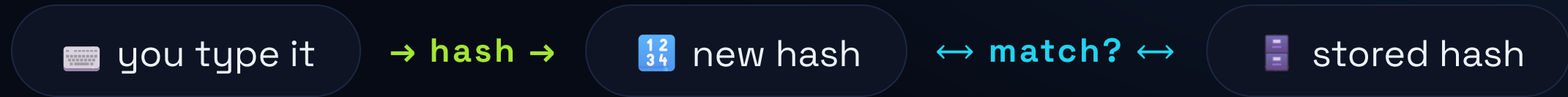
```
"password123" → hash → ef92a7c4d1...
```

```
# try to go back?
```

```
ef92a7c4d1... → ??? # can't
```

- Any input becomes a fixed-length jumble.
- It's **one-way**: easy to compute, practically impossible to reverse.
- **Different** from encryption — that's reversible with a key. A hash is **not**.

Login = compare the hashes.



- You log in → the site hashes whatever you just typed.
- It compares that to the **stored hash**.
- Hashes match? Password was correct — verified **without** ever seeing the real one.

Add a pinch of **salt** first.

• • •

```
# two people, SAME password  
"hello" + salt_A → 9f1c...  
"hello" + salt_B → 4b7e...  
# different hashes!
```

- Before hashing, add a unique random value — a **salt**.
- Same password → **different** hashes for each person.
- Pre-computed attack tables (rainbow tables) stop working.
- Each password gets its **own** salt.

WHY IT MATTERS

This is your **real-world** shield.

- A good data breach leaks only **hashes** — not your real password.
- “We’ll email you your password” is a huge **red flag** — it means they store it in plain text.
- Never **reuse** the same password across sites — one leak shouldn’t unlock everything.

COMMON MYTH — "YEH GALAT SAMAJHTE HAIN"

X MYTH

"Websites store my password (maybe **encrypted**) and could read it if they wanted."

✓ REALITY

A proper site stores a one-way **salted hash**. It can verify you, but can **never recover** your password. Encryption can be undone — a hash cannot.

RECAP — 2 THINGS TO REMEMBER

- 1 Passwords are stored as **one-way, salted hashes** — never the real thing.
- 2 Login works by **comparing hashes**, so your real password is never kept anywhere.

That's the **season!** 🎉

▶ **Subscribe @KatixoKhojLab**

More khoj coming — **what should we explain next?** Comment below. 💬